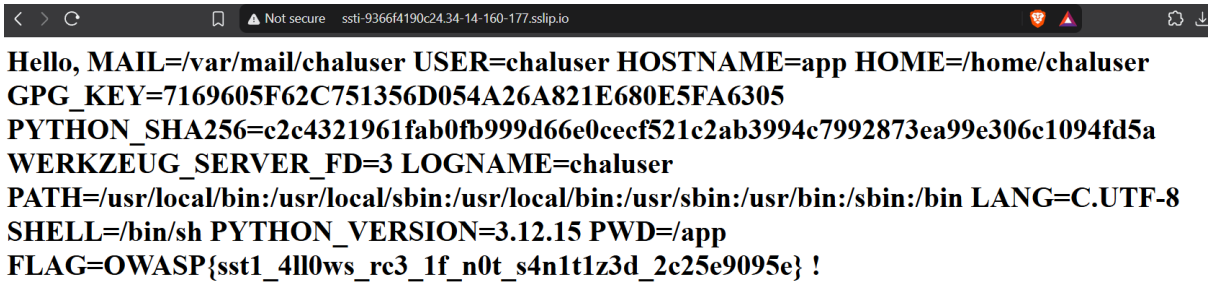
Template Terror

The landing page had a input box in it , I initially tried the classic jinja tag operation {{7*7}} It returned hello 49! And that conformed the vulnerability of the task checked for the flag location and information and that revealed that flag was in an environment, then created a jinja tag payload to read the content of environment and that revealed the flag

PAYLOAD: {{cycler.__init__.__globals__.os.popen("env").read()}}



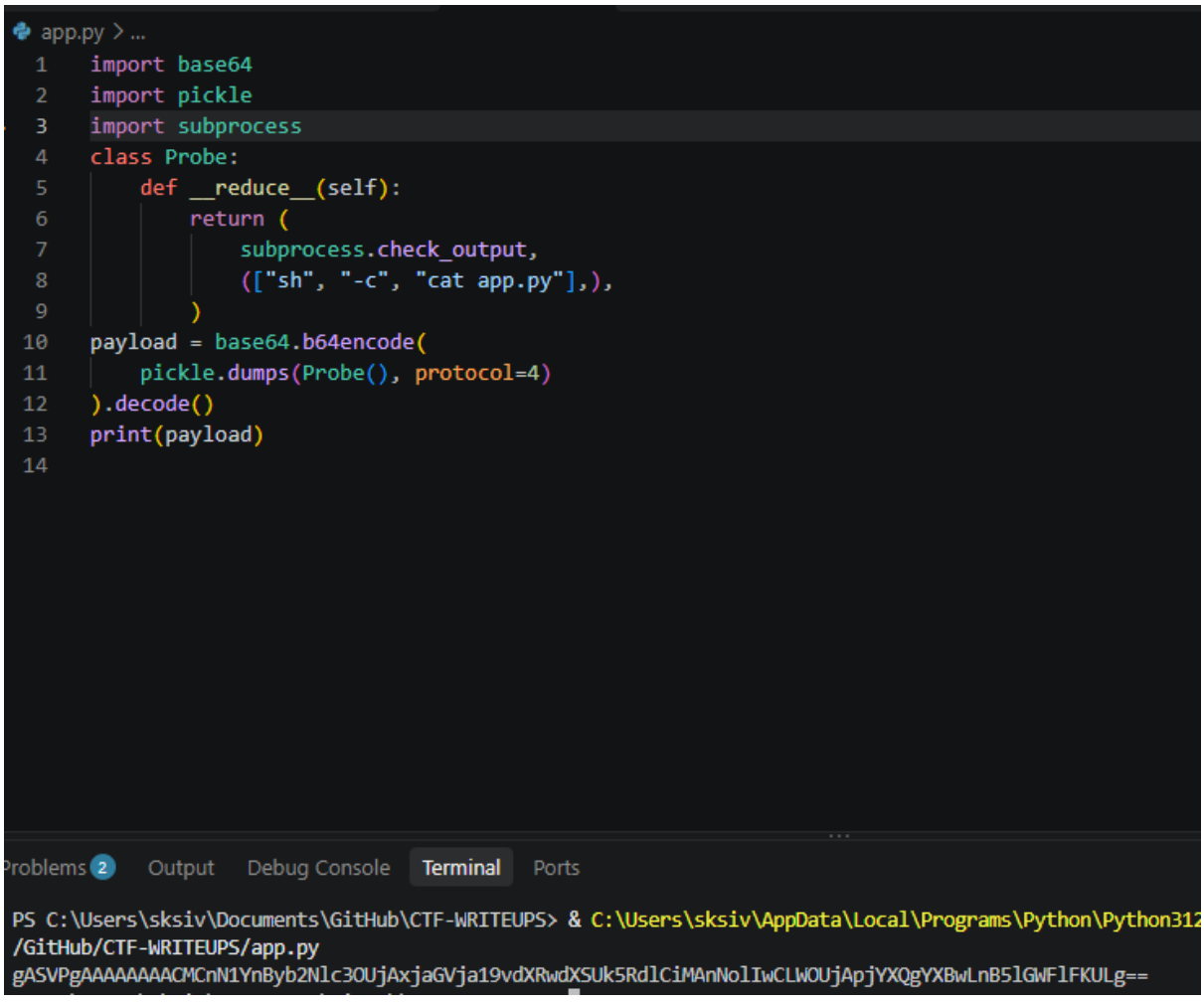
Flag: OWASP{sst1_4ll0ws_rc3_1f_n0t_s4n1t1z3d_2c25e9095e}

Pick Your Poison

This was my favorite challenge in this whole ctf , the challenge was similar to a tryhackme room picklerickle from the home page I had a huge sus on pickle deserialization

Inspected the pagesource and gave some json as input and noticed the out the server gave then I tried a pickle __reduce__ which I got from documentation pages then checked the vulnerability and the server was vulnerable for it

What the payload does is with the help of pickle and and __reduce__ it deserialize it and make the server vulnerable for data extraction , our payload crafted that properly and initaly I checked what are all in the directory and found and app.py file the next task is to open the file and read the content a python script was crafted for it and excecuted and returned a base64 took that and pasted in the json input and content off app.py

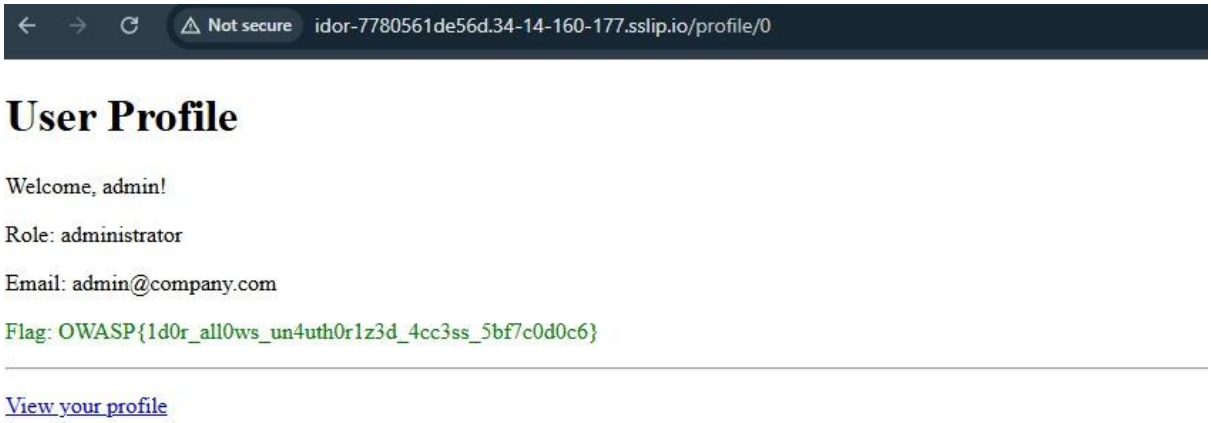


, render_template_string\n\napp = Flask(__name__)\n\nFLAG = "OWASP{d3s3r14l1z4t10n_c4n_b3_d4ng3r0us_43b337846a}

Flag: OWASP{d3s3r14l1z4t10n_c4n_b3_d4ng3r0us_43b337846a}

Hidden profiles

This was a very simple challenge where we have to try diiferent endpoints to find the flag. As soon as we open the site we are told to visit /profile/1 . I tried to access different profiles by changing the number from 1 to 2 and 3 and so on. There were no profiles after 3 so I tried and 10 and 0. The hidden profile was in 0.



Flag: OWASP{1d0r_all0ws_un4uth0r1z3d_4cc3ss_5bf7c0d0c6}